

TP1 Azure — ShopEasy — Livrables des ateliers

Cas fil rouge : migration de l'application de gestion de commandes **ShopEasy** vers Microsoft Azure. Région de déploiement : **swedencentral** — Resource Group : **rg-shopeasy-dev**.

Note de déploiement : l'abonnement *Azure for Students* impose une policy limitant les régions autorisées (**francecentral** interdite). La région retenue est donc **swedencentral**. De plus, le gabarit **Standard_B1s** étant indisponible (capacité), les VM utilisent **Standard_B2ts_v2** (2 vCPU, 1 Gio, burstable v2).

Atelier 1 — Analyse de l'existant

Tableau d'analyse

Domaine	Risque ou limite identifiée	Impact possible pour l'entreprise
Disponibilité	Serveur physique unique = point de défaillance unique (SPOF) ; aucune redondance ; pas de répartition de charge	Arrêt total de l'application en cas de panne matérielle → blocage des commandes, perte de chiffre d'affaires, indisponibilité pour le service client et la logistique
Sécurité	Compte administrateur partagé ; serveur exposé sans filtrage réseau structuré ; pas de cloisonnement des couches	Aucune traçabilité des actions, fuite de credentials, surface d'attaque large, intrusion possible et compromission des données clients
Performance	Web + base MySQL + stockage de fichiers sur la même machine ; ressources partagées	Contention CPU/IO ; pic de charge sur la base qui ralentit le web ; pas de scalabilité horizontale
Exploitation	Aucune supervision centralisée ; pas d'alerting	Incidents détectés tardivement (souvent par l'utilisateur) ; diagnostic lent ; MTTR élevé
Coût	Coûts non maîtrisés / non analysés ; dimensionnement figé	Sur- ou sous-dimensionnement ; aucune optimisation possible faute de mesure
Sauvegarde	Sauvegardes manuelles et irrégulières ; documents et base sur disque local	Perte de données en cas de panne disque ; RPO/RTO non garantis ; pas de test de restauration

Réponses aux questions guidées

1. **Panne du serveur physique** → indisponibilité totale et immédiate de l'application web, de la base et des documents (tout est sur la même machine). Aucun basculement automatique : arrêt de l'activité jusqu'à réparation/restauration, avec risque de perte de données si la dernière sauvegarde est ancienne.
2. **Base de données locale** → elle partage les ressources avec le web (contention), n'est ni redondée ni sauvegardée automatiquement, et tombe avec le serveur. Risque de corruption et de perte de données ; aucune haute disponibilité.
3. **Absence de supervision** → on ne détecte ni les saturations (CPU, disque), ni les pannes, ni les comportements anormaux. Les incidents sont découverts par les utilisateurs, le diagnostic est long et il n'existe aucun historique pour analyser les causes.

4. **Compte administrateur partagé** → perte de traçabilité (impossible de savoir qui a fait quoi), droits trop larges, et un seul secret compromis donne un accès total. Contraire au principe du moindre privilège et aux exigences d'audit.
5. **Éléments à séparer dans la cible** → couche web (VM applicatives), couche données (base managée), couche stockage (objet/blob), couche réseau (VNet/subnets/NSG), et la gouvernance des identités (comptes nominatifs + RBAC).

Besoins techniques prioritaires : haute disponibilité (redondance + load balancer), base managée, stockage objet externalisé, segmentation réseau et filtrage, supervision/alerting, identités nominatives + RBAC, sauvegardes automatisées.

Atelier 2 – Choix des services Azure

Tableau de choix

Besoin	Service Azure choisi	Justification	Modèle
Hébergement de l'application	Azure Virtual Machines	Migration « lift-and-shift » sans refonte immédiate de l'appli existante	IaaS
Répartition de charge	Azure Load Balancer (Application Gateway en prod)	Distribue le trafic sur 2 VM, supprime le SPOF web	IaaS / PaaS
Base de données	Azure SQL Database	Base managée : sauvegardes, patchs, HA gérés par Azure ; réduit l'administration	PaaS
Stockage des documents	Azure Storage Account (Blob)	Stockage objet durable, externalisé de la VM, versioning et cycle de vie	PaaS
Isolation réseau	Azure Virtual Network + subnets	Cloisonne web / data / admin et permet un filtrage précis	IaaS
Filtrage réseau	Network Security Groups	Limite les flux entrants/sortants aux besoins réels	IaaS
Gestion des accès	Microsoft Entra ID + RBAC	Comptes nominatifs, moindre privilège, MFA, traçabilité	Gouvernance
Monitoring	Azure Monitor	Métriques, logs, alertes, tableaux de bord	PaaS / Gouvernance
Suivi des coûts	Azure Cost Management	Analyse, budgets, optimisation, exploitation des tags	Gouvernance

Question de justification (IaaS / PaaS / gouvernance)

- **IaaS (VM, VNet, NSG)** : l'équipe reste responsable de l'OS, des correctifs, du runtime et de l'application → charge d'exploitation élevée.
- **PaaS (Azure SQL, Storage, App Gateway)** : Azure gère l'infrastructure et une partie de l'exploitation (patchs, HA, sauvegardes) → l'équipe se concentre sur la donnée et la configuration → responsabilité réduite.

- **Gouvernance (Entra ID/RBAC, Cost Management)** : ne porte pas l'applicatif mais encadre sécurité, droits et coûts → responsabilité transverse.

Plus on va vers le PaaS, plus la responsabilité opérationnelle bascule vers Azure (modèle de responsabilité partagée), ce qui réduit le risque humain et la charge d'administration.

Atelier 3 — Architecture cible Azure

Voir le schéma détaillé en **Étape 3** ([03_architecture/](#)). Composants minimaux retenus :

- 1 région (`swedencentral`) + 1 Resource Group `rg-shopeasy-dev`
- 1 VNet `10.10.0.0/16` segmenté en 3 subnets : `snet-web` (10.10.1.0/24), `snet-data` (10.10.2.0/24), `snet-admin` (10.10.3.0/24)
- 2 VM web (`vm-web-01` , `vm-web-02`) dans `snet-web`
- 1 Azure Load Balancer en frontal (exposé Internet)
- 1 Azure SQL Database (accès limité au subnet web)
- 1 Storage Account privé (conteneurs `factures` , `clients` , `archives`)
- NSG `nsg-web` et `nsg-data`
- Azure Monitor (métriques + alertes)
- Entra ID + RBAC pour l'administration

Flux exposés à Internet : uniquement le Load Balancer (80/443) et, temporairement, SSH (22) restreint à l'IP de l'apprenant. **Composants internes** : SQL Database, Storage Account, subnet data.

Atelier 4 — Préparation de l'environnement

Convention de nommage complétée (suffixe d'exemple : `of24`)

Ressource	Nom
Resource Group	<code>rg-shopeasy-dev</code>
Virtual Network	<code>vnet-shopeasy-dev</code>
Subnet web	<code>snet-web</code>
Subnet data	<code>snet-data</code>
NSG web	<code>nsg-web</code>
NSG data	<code>nsg-data</code>
VM 1	<code>vm-web-01</code>
VM 2	<code>vm-web-02</code>
Storage Account	<code>stshopeasyof24</code>
Azure SQL Server	<code>sql-shopeasy-of24</code>
Azure SQL Database	<code>sqlldb-shopeasy</code>

Réponses aux questions de validation

1. **Resource Group dédié** : regroupe le cycle de vie des ressources d'un projet (création, droits, tags, suivi de coûts, suppression en bloc). Facilite la gouvernance et le nettoyage.
2. **Tags** : identifient propriétaire, projet, environnement et centre de coût → indispensables pour le suivi FinOps, la facturation par projet et l'automatisation (ex. arrêt programmé).
3. **Sans convention de nommage** : ressources illisibles, doublons, erreurs de manipulation, difficulté à filtrer/auditer et à automatiser ; gouvernance et reprise par un tiers compliquées.

Atelier 5 — Réseau Azure

Plan d'adressage déployé (voir script Étape 2).

Pourquoi une seule grande plage ne suffit pas : un réseau plat ne permet pas d'appliquer des règles de sécurité différenciées par fonction, autorise les mouvements latéraux entre composants compromis, et empêche le placement d'endpoints privés/bastion dédiés. La segmentation (web/data/admin) applique le principe de défense en profondeur et de moindre exposition.

Atelier 6 — Filtrage NSG

Règles déployées

NSG	Port	Source	Justification
nsg-web	80	Internet	Accès HTTP à l'application de test
nsg-web	443	Internet	Accès HTTPS cible en production
nsg-web	22	IP apprenant /32	Administration Linux limitée à une IP
nsg-data	1433	subnet web uniquement	Accès SQL réservé aux serveurs web

Réponses aux questions de sécurité

1. **SSH limité à une IP** : réduit drastiquement la surface d'attaque (brute force, scans) ; seul l'administrateur identifié peut se connecter.
2. **Ne pas exposer SQL sur Internet** : la base contient des données sensibles ; l'exposer multiplie les risques d'injection, brute force et exfiltration. L'accès doit rester interne (subnet web ou Private Endpoint).
3. **Règle entrante vs sortante** : l'entrante filtre le trafic *vers* la ressource (qui peut l'atteindre), la sortante filtre le trafic *émis par* la ressource (vers où elle peut parler) — utile pour limiter l'exfiltration.
4. **Évolution en production** : suppression de SSH public au profit d'**Azure Bastion**, HTTPS obligatoire via Application Gateway + WAF, **Private Endpoint** pour SQL et Storage, NSG plus restrictifs et journalisation des flux (NSG Flow Logs).

Atelier 7 — Déploiement des VM web

Vérifications attendues

1. Les deux VM `vm-web-01` et `vm-web-02` apparaissent dans `rg-shopeasy-dev`.
2. `systemctl status nginx` → service `active (running)`.
3. La page de test est accessible via l'IP publique de chaque VM (port 80).
4. Les pages affichent respectivement « ShopEasy - VM Web 01 » et « ShopEasy - VM Web 02 » → identification de la VM servie.

Commandes dans le script de l'Étape 2.

Atelier 8 — Répartition de charge

Analyse

1. **VM indisponible** : la sonde de santé la détecte et le Load Balancer cesse de lui router du trafic → le service reste disponible via l'autre VM (dégradation, pas d'interruption).
 2. **Sonde de santé** : sans elle, le répartiteur enverrait du trafic vers une VM morte → erreurs pour l'utilisateur. La sonde garantit que seules les instances saines reçoivent du trafic.
 3. **Limites substantielles** : la base de données et le Storage restent des points uniques s'ils ne sont pas redondés ; les 2 VM dans une même zone tombent ensemble en cas de panne de zone ; pas de WAF/TLS avancé avec un simple Load Balancer.
 4. **Multi-zone** : déployer les VM dans des Availability Zones distinctes protège contre la panne d'un datacenter entier → disponibilité nettement supérieure.
-

Atelier 9 — Stockage documentaire

Travail demandé (synthèse)

Storage Account `stshopeasyof24` créé (Standard_LRS, StorageV2, HTTPS only, TLS 1.2), conteneurs `factures`, `clients`, `archives`. Chiffrement au repos actif par défaut ; versioning des blobs activé. Le stockage objet remplace le répertoire local : découplé de la VM, durable, accessible par API et indépendamment scalable.

Réponses aux questions

1. **Objet vs disque local** : durabilité élevée (réplication), capacité quasi illimitée, accès indépendant des VM, intégration sauvegarde/cycle de vie, pas de perte si la VM tombe.
2. **Éviter les conteneurs publics** : un conteneur public expose les documents clients à tout Internet → fuite de données personnelles. L'accès doit être authentifié (clé/SAS/identité managée).
3. **Versioning** : conserve les versions précédentes → protège contre l'écrasement et la suppression accidentelle, et permet la restauration.
4. **Cycle de vie pour les archives** : déplacer automatiquement les blobs anciens vers un tier *Cool* puis *Archive* après X jours, et supprimer au-delà de la durée de rétention légale → réduction des coûts.

Atelier 10 — Azure SQL Database

Comparaison VM SQL vs Azure SQL Database

Critère	Base sur VM	Azure SQL Database
Administration	À la charge de l'équipe (instance, config)	Gérée par Azure
OS	À patcher et maintenir	Aucun OS à gérer
Sauvegardes	Manuelles à configurer	Automatiques (PITR intégré)
Mises à jour	Manuelles (OS + moteur SQL)	Automatiques
Haute disponibilité	À construire (cluster, réplicas)	Intégrée (options zone-redundant)
Sécurité	Entièrement à la charge de l'équipe	Chiffrement, auditing, Defender intégrés
Coût	VM allumée 24/7 + licence + exploitation	Modèle managé, tiers ajustables (DTU/vCore, serverless)
Flexibilité	Contrôle total (versions, extensions)	Plus encadré, moins de contrôle bas niveau

La base ne doit **pas** être exposée librement : règles réseau limitées, idéalement Private Endpoint et identités managées en production.

Atelier 11 — Supervision (Azure Monitor)

Tableau d'indicateurs

Indicateur	Seuil proposé	Pourquoi le surveiller ?
CPU VM	> 80 % pendant 5 min	Anticiper la saturation et le besoin de scaler
Disponibilité HTTP	< 99 % sur 5 min	Détecter une panne applicative côté utilisateur
Espace disque	< 15 % libre	Éviter l'arrêt des services par disque plein
Échecs de connexion (SQL/SSH)	> 10 / min	Détecter brute force ou problème de configuration
Coût journalier	> budget quotidien défini	Alerter sur une dérive budgétaire (FinOps)

3 indicateurs utiles en production : latence applicative (p95), taux d'erreurs HTTP 5xx, santé du backend pool du load balancer.

Atelier 12 — Coûts et FinOps

Tableau de coûts (estimation indicative — Sweden Central, à confirmer via Azure Pricing Calculator)

Ressource	Hypothèse	Coût estimé (€/mois)	Optimisation possible
VM web 1	Standard_B2ts_v2, 730 h	~9–12 €	Arrêt hors formation ; auto-shutdown
VM web 2	Standard_B2ts_v2, 730 h	~9–12 €	Idem ; réservation si usage stable
Disques	2× OS Standard SSD	~5 €	Taille adaptée ; suppression si VM supprimée
Load Balancer	Standard, faible trafic	~18–20 €	Basic en test ; mutualisation
Storage Account	LRS, quelques Go	~1–2 €	Cycle de vie Cool/Archive
Azure SQL Database	Serverless / Basic	~5–15 €	Serverless auto-pause hors usage
Monitoring	Métriques + 1 alerte	~0–3 €	Limiter la rétention des logs
Total		~45–65 €/mois	

Réponses FinOps

1. **Coûtent même inutilisées** : VM allumées, disques managés, IP publiques réservées, Load Balancer, base provisionnée (non serverless).
2. **À arrêter hors formation** : les VM (auto-shutdown), la base en serverless (auto-pause). On peut aussi supprimer entièrement le RG.
3. **Tags** : permettent de ventiler et analyser les coûts par projet/environnement/propriétaire, et de poser des budgets ciblés.
4. **Réduire vs optimiser** : *réduire* = dépenser moins (couper des ressources). *Optimiser* = obtenir le meilleur rapport valeur/coût (bon dimensionnement, bon modèle de facturation, automatisation) sans dégrader le service.

Atelier 13 — Analyse de disponibilité

Scénario	Impact	Solution proposée
Une VM web tombe	Capacité réduite, pas d'interruption (LB)	2+ VM derrière LB ; scale set ; multi-zone
Load Balancer mal configuré	Trafic mal routé / erreurs	Sonde de santé correcte, règles validées, tests
Base de données indisponible	Application non fonctionnelle (lecture/écriture KO)	Azure SQL HA zone-redundant, réplicas, sauvegardes PITR

Scénario	Impact	Solution proposée
Storage Account mal configuré	Documents inaccessibles ou exposés	Redondance (ZRS/GRS), accès privé, contrôle d'accès
Zone de disponibilité indisponible	Perte des composants mono-zone	Déploiement multi-zone des VM, LB et base

Synthèse : l'architecture de TP **ne suffit pas** pour une application critique (mono-zone, base/storage à fiabiliser). Évolutions nécessaires : déploiement multi-zone, SQL zone-redondant, sauvegardes + tests de restauration formalisés, supervision avancée et plan de reprise (PRA/PCA).

Atelier 14 — Analyse de sécurité

Matrice de risques

Risque	Impact	Probabilité	Mesure corrective
SSH ouvert à Internet	Intrusion (brute force)	Élevée	NSG limité à une IP /32 ; Azure Bastion ; clés SSH
Compte admin partagé	Perte de traçabilité, compromission globale	Élevée	Comptes nominatifs Entra ID + RBAC + MFA
Stockage public	Fuite de données clients	Moyenne	Conteneurs privés ; accès par SAS/identité managée
Base exposée	Exfiltration / injection	Moyenne	Pare-feu SQL restreint ; Private Endpoint
Absence d'alertes	Détection tardive des incidents	Élevée	Azure Monitor + alertes + logs d'activité
Droits excessifs	Erreurs / abus	Moyenne	RBAC, principe du moindre privilège

Plan d'actions par priorité : 1. (P1) Comptes nominatifs + MFA + RBAC ; fermer SSH public (Bastion). 2. (P1) Storage et base en accès privé uniquement. 3. (P2) Alerting + journalisation activés. 4. (P2) Chiffrement vérifié, sauvegardes + tests de restauration. 5. (P3) Suppression des ressources/accès inutiles, revue régulière des droits.

Atelier 15 — Note de recommandations DSI

Voir le document dédié [02_note_DSI.md](#).